

Red Teaming de Sistemas de IA

Módulo 12 · Seguridad en IA

Manual vs automatizado, Garak/DeepTeam/PyRIT, 5 vectores principales, proceso de 5 fases y golden dataset adversarial.

1. Introducción · 2. Qué es · 3. Cómo funciona · 4. Ejemplos reales
5. Errores comunes · 6. Aplicación práctica · 7. Relación con módulos · 8. Resumen ejecutivo

Guía de estudio detallada · +2.000 palabras

Red Teaming de Sistemas de IA

El red teaming es la práctica de simular ataques adversariales para identificar vulnerabilidades antes de que los atacantes reales las exploten. En el contexto de sistemas de IA, el red teaming no se limita a los vectores de ataque de ciberseguridad tradicionales: incluye también los vectores específicos de IA (jailbreaks, prompt injection, data poisoning, sesgos, y comportamientos dañinos). OWASP publicó su Gen AI Red Teaming Guide en enero 2025, formalizando esta disciplina para sistemas de IA generativa.

El mandato regulatorio del red teaming está creciendo: el Executive Order 14110 de EE.UU. requiere que los desarrolladores de modelos frontier entreguen los resultados de red teaming pre-lanzamiento. El EU AI Act artículo 15 requiere "robustez y ciberseguridad" que se interpreta como testing adversarial documentado. La carrera armamentista entre atacantes y defensores hace que el red teaming que funcionaba ayer no sea suficiente mañana: los red teams deben simular ataques adaptativos, no solo los ataques conocidos.

Red teaming manual vs automatizado

Red teaming manual: expertos humanos

El red teaming manual involucra investigadores de seguridad y expertos en IA que diseñan y ejecutan ataques creativos y adaptativos. Es el enfoque más efectivo para encontrar vulnerabilidades sofisticadas y nuevas (zero-days de IA). Las organizaciones que realizan red teaming manual con más rigor son los propios proveedores de modelos (Anthropic, OpenAI, Google DeepMind) que tienen equipos dedicados de red teaming interno, y servicios especializados (HackerOne AI Red Teaming, Adversa AI, HiddenLayer). Para la mayoría de las organizaciones, el red teaming manual debe complementarse con red teaming automatizado para escala y repetibilidad.

Red teaming automatizado: cobertura a escala

El red teaming automatizado usa herramientas que generan y ejecutan ataques sistemáticamente. Las herramientas principales en 2025 son: Garak (NVIDIA, open source): escáner de vulnerabilidades LLM con plugins para docenas de categorías de ataques (jailbreaks, prompt injection, PII leakage, información dañina). DeepTeam (Confident AI, noviembre 2025): aplica jailbreaks y prompt injection iterativamente, refinando los ataques para maximizar la tasa de éxito. PyRIT (Microsoft, open source): framework de red teaming con soporte para múltiples orquestadores y tipos de ataque. Promptfoo (open source): testing de prompts y modelos con cobertura del OWASP Top 10.

Los cinco vectores de ataque principales del red teaming LLM

Los cinco vectores que el red team debe cubrir de forma sistemática, mapeados al OWASP LLM Top 10: (1) Prompt injection directa e indirecta (LLM01). (2) Extracción de información sensible: system prompt, datos de otros usuarios, datos de entrenamiento (LLM02, LLM07). (3) Jailbreak

para contenido dañino: violencia, instrucciones ilegales, contenido discriminatorio (LLM04, LLM09). (4) Abuso de herramientas y agencia excesiva (LLM06). (5) Denegación de servicio por consumo (LLM10).

SECCIÓN 3 · CÓMO FUNCIONA

El proceso de red teaming de sistemas de IA

El proceso de red teaming de 5 fases de Hacken: Fase 1 (Scope): define el sistema a testear, los vectores de ataque en scope, y los objetivos del red team (¿qué intentas encontrar? ¿qué nivel de confianza en el sistema quieres demostrar?). Fase 2 (Vulnerability Assessment): testea sistemáticamente cada vector del scope con la lista de técnicas de ataque conocidas. Fase 3 (Exploit Development): para los ataques que tuvieron algún nivel de éxito en la fase anterior, refina los prompts o payloads para maximizar la fiabilidad del ataque. Fase 4 (Impact Analysis): para cada exploit confirmado, estima el impacto de negocio si un atacante real lo explotara. Fase 5 (Reporting): documenta los hallazgos con exploit demos, nivel de criticidad, y guidance de remediación.

El golden dataset adversarial: cada sistema de IA debe tener un golden dataset adversarial que captura los peores casos de seguridad que el sistema debe rechazar definitivamente. Este dataset se construye a partir de los resultados del red teaming inicial y se actualiza con cada nuevo tipo de ataque identificado. El golden dataset adversarial es el test suite de seguridad del sistema: se ejecuta en CI/CD en cada cambio y antes de cada despliegue. Si el sistema pasa el golden dataset adversarial, la seguridad mínima está verificada.

Métricas del red teaming

Las métricas que un informe de red teaming debe incluir: Attack Success Rate (ASR) por categoría de ataque (qué porcentaje de los ataques de cada tipo tuvieron éxito), Time to Jailbreak (tiempo promedio para generar un ataque exitoso, si se encontró alguno), cobertura del OWASP Top 10 (qué categorías se testearon y con qué profundidad), severidad de los hallazgos (crítico/alto/medio/bajo según el impacto de negocio), y comparación con baseline (si el sistema es más o menos seguro que en el último red teaming).

SECCIÓN 4 · EJEMPLOS REALES

- Red teaming de Claude en HackerOne (2024): HackerOne coordinó un red team externo de Claude con más de 300.000 interacciones adversariales y 3.700+ horas de testing. El resultado: cero jailbreaks universales encontrados. Se documentaron vulnerabilidades de contexto específicas que fueron corregidas. Este es el tipo de red teaming exhaustivo que justifica las afirmaciones de seguridad de un modelo para uso empresarial.
- Garak en producción (equipo de seguridad, empresa tecnológica): integración de Garak en el pipeline de CI/CD. Configuración: `garak --model openai --model_type gpt-4o --probes continuation,knowledgegrounding,jailbreak`. El pipeline ejecuta Garak en cada PR que modifica los prompts o la configuración del sistema. Si Garak encuentra una vulnerabilidad nueva (ASR mayor que el baseline), el PR es bloqueado y el equipo recibe una notificación.
- Red teaming de agente con herramientas (empresa fintech): el red team específico del agente de análisis financiero testeó: injection via documentos PDF maliciosos (los análisis

de mercado externos que el agente descargaba), SSRF via la herramienta de búsqueda web del agente, y escalada de privilegios via el sistema de handoffs entre agentes. Se identificaron 3 vulnerabilidades críticas que fueron corregidas antes del despliegue a producción.

SECCIÓN 5 · ERRORES Y MALENTENDIDOS COMUNES

Error 1: Red teaming de una sola vez antes del lanzamiento, sin periodicidad. Los ataques evolucionan constantemente. Un red teaming exhaustivo realizado hace 6 meses puede no haber cubierto las técnicas de ataque que aparecieron en los últimos 3 meses. Implementa red teaming automatizado continuo (en CI/CD) y red teaming manual periódico (al menos semestral).

Error 2: Testear solo el modelo, no el sistema completo. El sistema de IA no es solo el modelo: incluye el prompt de sistema, las herramientas disponibles, el corpus RAG, la integración con los sistemas externos, y la infraestructura de despliegue. Cada componente tiene sus propios vectores de ataque. El red teaming debe cubrir el sistema completo, no solo el comportamiento del LLM en aislamiento.

Error 3: No priorizar los hallazgos por impacto de negocio. Un jailbreak que hace que el modelo responda en el idioma incorrecto y uno que hace que revele datos de otros clientes son vulnerabilidades de distinta gravedad. Prioriza la remediación según el impacto potencial de negocio (criticidad de los datos, reversibilidad de las acciones, escala del daño posible).

SECCIÓN 6 · APLICACIÓN PRÁCTICA

Para configurar Garak para red teaming automatizado: `pip install garak`. Ejecutar un escaneo completo: `python -m garak --model openai --model_type gpt-4o --probes all --generations 10`. Para un escaneo específico del OWASP Top 10: `python -m garak --model openai --model_type gpt-4o --probes jailbreak,continuation,dan,knowledgegrounding`. Para integración en CI/CD: el job de Garak ejecuta el escaneo y genera un informe JSON; si el ASR supera el umbral definido para cualquier categoría, el job falla y bloquea el PR.

El proceso mínimo de red teaming para equipos pequeños: semana 1: ejecutar Garak sobre el sistema y documentar los resultados (ASR por categoría). Semana 2: para cada vulnerabilidad encontrada, desarrollar un exploit confiable y estimar el impacto de negocio. Semana 3: implementar las mitigaciones para las vulnerabilidades críticas y altas. Semana 4: re-ejecutar Garak para verificar que las mitigaciones son efectivas. Repetir cada trimestre o ante cambios mayores en el sistema.

SECCIÓN 7 · RELACIÓN CON OTROS MÓDULOS

- M12-T1 (OWASP Top 10): el red teaming debe cubrir sistemáticamente todas las categorías del OWASP LLM Top 10.
- M12-T8 (Secure AI DLC): el red teaming es el componente de testing de seguridad del Secure AI DLC.
- M13 (Gobernanza): el informe de red teaming es parte de la documentación técnica requerida por el EU AI Act.

Red teaming de IA simula ataques adversariales para encontrar vulnerabilidades antes de los atacantes. Los dos enfoques son: manual (expertos humanos, más creativo, mejor para zero-days) y automatizado (Garak, DeepTeam, PyRIT, Promptfoo; cobertura sistemática y repetible). Los 5 vectores principales: prompt injection, extracción de información, jailbreak para contenido dañino, abuso de herramientas, y DoS por consumo. El proceso de 5 fases: scope, vulnerability assessment, exploit development, impact analysis, reporting. El golden dataset adversarial es el test suite de seguridad continuo. Mandato regulatorio: EO 14110 (EE.UU.), EU AI Act (artículo 15). El informe de red teaming es un activo de compliance para sistemas de alto riesgo.